Meal*Mate.*

Командная презентация: системы баз данных, кибербезопасность и мультимедийные технологии — на примере нашего веб-приложения.

CS-2618 · ICT · Team presentation

Samarin · Kaniyazov · Sadybek · Temirtas



КОНТЕКСТ — НАШ ПРОЕКТ

MealMate: подбирает рецепты из того, что уже есть дома.

68

рецептов, 5 кухонь
(14 казахских)

51

ингредиент в пикере,
0 «мёртвых»

3

языка интерфейса
и шагов: EN·РУ·ҚАЗ

7

таблиц БД = ER-модель
из Assignment 3

Стек: React 18 (Vite) → Express (Node.js 24) → SQLite (node:sqlite). Всё, что дальше, — реальные механизмы этого приложения, а не абстракции из учебника.

Три темы — три слоя нашего продукта: Базы данных — на чём хранится и как ищется · Кибербезопасность — как защищаются пользователи · Мультимедиа — как обрабатываются фото и движения интерфейса

ER-модель из Assignment 3 — реализована 1:1, плюс расширения.

users

user_id · name · email UQ
password_hash · is_guest

ingredients

name · name_ru/kk · emoji
category · is_staple

recipes

КБЖУ · time · servings
tags · featured · title_ru/kk

instruction_blocks

step_number UNIQUE
в рецепте · description ×3 яз.

user_ingredients

junction M:N: user ↔ ingredient
кладовая пользователя

recipe_ingredients

junction M:N: recipe ↔ ingredient
quantity · unit · optional

photo_diary

photo (data-URL) · note
uploaded_at · user → recipe

app_meta + reset_tokens

секрет сессий · одноразовые
токены сброса пароля

M:N-связи решены junction-таблицами (user_ingredients, recipe_ingredients).

Бизнес-правила: уникальный e-mail; номер шага уникален в рецепте; все связи — FOREIGN KEY с ON DELETE CASCADE.

Расширения (не ломая ER): is_staple — базовые продукты не считаются «не хватает»; КБЖУ и теги; локализованные колонки title/name/description_ru/kk для мультиязычного контента.

Подбор рецептов: один SQL-запрос с двумя CTE.

missing = total – have total — обязательные (optional=0, is_staple=0) · have — есть у пользователя

CTE req	SELECT recipe_id, COUNT(*) FROM recipe_ingredients … GROUP BY recipe_id — сколько обязательных ингредиентов в каждом рецепте
CTE got	то же, но JOIN с выбором пользователя — сколько из них уже есть; missing = total − have
Правила	0 → «готовить сейчас» · 1–2 → «почти готово» · have ≥ 1 — гарантия пересечения (лечит баг «креветки → блюда без креветок») · при выборе 1–2 продуктов порог адаптивно расширяется

Индексы на junction-таблицах и diary(user_id); фильтры времени/кухни/тегов — в том же запросе; только параметризованные выражения. Почему SQLite: персистентность без сервера БД, замена на PostgreSQL — через тонкий слой db.js без правки роутов.

II. КИБЕРБЕЗОПАСНОСТЬ — ПОЛЬЗОВАТЕЛИ

Пароли, сессии и восстановление — своими руками, без «магии».

Пароли	scrypt + индивидуальная соль на пользователя; сравнение timingSafeEqual — утечка базы не раскрывает пароли, подмена — не проходит
Сессии	кука httpOnly + SameSite=Lax, подпись HMAC-SHA256 от содержимого: подделать ID без секрета сервера невозможно
Гостевые аккаунты	работа без регистрации: при первом действии создаётся guest-строка; при регистрации она апгрейдится — данные переносятся
Сброс пароля	одноразовый токен: SHA-256 хэш в БД, живёт 30 минут, одноразовый; в демо «письмо» показывается на экране

Угроза → контрмера: каждая пара — реально в коде.

Угроза	Контрмера в MealMate
SQL-инъекция через поля поиска и фильтры	только параметризованные запросы (node:sqlite), ни одной конкатенации строк
XSS через заметки дневника и имена	React экранирует вывод; вход строго валидируется (тип, длина, белый список)
Перебор паролей и спам загрузок	rate-limit по IP: 40 запросов / 10 мин на auth, отдельный лимит на diary
«Тяжёлое» фото как DoS	лимит тела 6 МБ + сжатие в браузере до JPEG ≤ ~3 МБ + проверка MIME
Кража сессии / кликджекинг	httpOnly + SameSite cookie, security-заголовки helmet
Подделка чужой записи дневника	каждая операция проверяет user_id владельца; гостям API отвечает 401

Приватность: гостевые записи дневника не попадают в общую ленту; собираем только имя, e-mail и фото блюд — никаких платёжных или иных чувствительных данных.

Фото-дневник: полный конвейер обработки в браузере.

1

Выбор файла

FileReader,
проверка MIME

→

2

Уменьшение

canvas: максимум
1280 px по стороне

→

3

Сжатие

JPEG, качество 0.82
→ ~150–300 КБ

→

4

Передача

data-URL → POST,
валидация на сервере

→

5

Хранение и показ

TEXT в SQLite,
ленивая загрузка <img>

Зачем сжимать в браузере: фото с телефона — это 3–8 МБ; после canvas — 200 КБ. Экономия ×20 на трафике и хранилище, загрузка мгновенная даже на мобильном интернете.

Фото рецептов: CDN Unsplash с проверенными ссылками; при недоступности — автоматический fallback: градиентная плитка с эмодзи кухни (ни одна карточка не выглядит «сломанной»). Ленивая загрузка loading="lazy", фиксированное соотношение сторон 16:10 — вёрстка не прыгает.

Анимации — на чистом CSS: ноль библиотек, полный контроль.

Scroll-reveal	IntersectionObserver: секции появляются с задержкой-каскадом (—stagger через CSS-переменную --rd)
Пружинный выбор	галочка на чипе ингредиента: scale с кубической кривой беззье (bounce), эмодзи увеличивается
Живые карточки	подъём на hover, зум фото 1.06, кольца прогресса матча (SVG stroke-dashoffset)
Счётчики и бегущая строка	count-up статистики на rAF; marquee ингредиентов — бесконечный CSS-цикл
Доступность	prefers-reduced-motion: все анимации отключаются — уважение к вестибулярному аппарату пользователя

Аудио и видео в продукте сознательно не используются: контент — текст и фото, лишние медиа замедляли бы загрузку на мобильном интернете.

ИТОГ — ТРИ ТЕМЫ, ОДИН ПРОДУКТ

Что это дало в сумме.

Базы данных	ER из Assignment 3 работает в продакшене; матчинг на SQL с гарантией релевантности; 0 «мёртвых» ингредиентов после аудита покрытия
Кибербезопасность	пароли не утекают при взломе БД, сессии неподделываемы, дневник недоступен гостям, каждая угроза из таблицы закрыта кодом
Мультимедиа	фото дневника сжимаются в 20 раз до отправки; ни одна карточка не выглядит сломанной; интерфейс живой, но уважает reduced-motion

Демо: localhost:3001 · GitHub: github.com/nafiks/mealmate · **Спасибо за внимание!**

CS-2618 · Samarin · Kaniyazov · Sadybek · Temirtas